

Information Security

Comprehensive Study Guide: Past Papers, Quizzes & Book Questions

Part 1: Past Papers & Quizzes

Midterm 1 – Fall 2025 (Spring 2025 Exam Paper)

QUESTION 1.1

Q: A message is first encrypted with a Caesar cipher (with key 3) and then the resulting text is again encrypted with monoalphabetic substitution cipher where A is mapped to F, B to K, and so on. A cryptanalyst knows this two-step process. What is the most effective way to break this combined cipher without trying to guess the original plain text?

- a) Brute force the Caesar cipher, then perform a frequency analysis on the intermediate text.
- b) Perform frequency analysis on the final ciphertext, then brute force the Caesar shifts.
- c) Brute force the monoalphabetic cipher, then brute force the Caesar cipher.
- d) Treat the combined cipher as a single monoalphabetic substitution cipher.

Answer: d) Treat the combined cipher as a single monoalphabetic substitution cipher.

QUESTION 1.2

Q: A cryptanalyst intercepts a ciphertext that is 300 characters long. They look for repeated strings, and find that the sequence UQE repeats at positions 25 and 100, while FPR repeats at positions 50 and 150. Which of the following is the most likely key length for the Vigenère cipher?

- a) 5
- b) 10
- c) 15
- d) 25

Answer: d) 25

Working:

Distance for UQE: $100 - 25 = 75$

Distance for FPR: $150 - 50 = 100$

$\gcd(75, 100) = 25$

QUESTION 2.A

Q: Which information security property is being most directly impacted in the following scenarios? Choose one from Confidentiality, Integrity, Availability, Authenticity, Accountability:

- i. During a ransomware attack, the company loses access to its systems until ransom is paid.**
- ii. An employee receives an email that looks like it is from their boss, but it was actually sent by a pretending attacker.**
- iii. University's online portal crashes on the day grades are released, leaving students unable to access results.**
- iv. An angry employee modifies payroll data so that some staff salaries are reduced.**

- i. Availability
- ii. Authenticity
- iii. Availability
- iv. Integrity

QUESTION 2.B

Q: Review the below scenario, and then discuss how you could apply the following security design principles to improve the system's security. Give specific examples relevant to this system:

- i. Least privilege**
- ii. Fail-safe defaults**

Scenario: A healthcare startup has developed an online medical consultation portal. Patients register and book virtual appointments with doctors. During the consultation, doctors access the patient's medical history stored in the system. After the session, doctors update the record with prescriptions and treatment notes. Patients can later download their prescriptions or share them with pharmacies.

i. Least Privilege: Doctors are only granted read/write access to the records of patients who have booked appointments with them, and only for the active consultation window. Pharmacies are granted read access solely to prescription details, not full patient medical history.

ii. Fail-Safe Defaults: The default access state for any user or visitor to any record is strictly "None" (deny-by-default). If a session crashes, errors out, or permissions expire, the system safely falls back to denying access.

QUESTION 3.A

Q: An adversary intercepts an encrypted message. He knows the message was first protected with a Caesar cipher with shift 3, but the output was then permuted using a rail fence cipher with a depth of 4. The final ciphertext is VWFHLBDKFUEHHXUV. Find the original plaintext message. Show your working.

Answer: SECURITYBREACHED

Working:

Ciphertext length = 16. Depth = 4. Cycle length = $2 \times (4 - 1) = 6$.

Character distribution across rows:

Row 0 (indices 0, 6, 12): V, W, F (3 chars)

Row 1 (indices 1, 5, 7, 11, 13): H, L, B, D, K (5 chars)

Row 2 (indices 2, 4, 8, 10, 14): F, U, E, H, H (5 chars)

Row 3 (indices 3, 9, 15): X, U, V (3 chars)

Reconstructing intermediate rail-fence text:

Index 0: V | Index 1: H | Index 2: F | Index 3: X | Index 4: U | Index 5: L | Index 6: W | Index 7: B |

Index 8: E | Index 9: U | Index 10: H | Index 11: D | Index 12: F | Index 13: K | Index 14: H | Index 15: V

Intermediate string: VHFUXULWBEUHDDFKHV → VHFUXULWBEUHDDFKH (16 chars).

Reversing Caesar cipher (Shift back by -3):

V → S, H → E, F → C, X → U, U → R, L → I, W → T, B → Y → SECURITY

E → B, U → R, H → E, D → A, F → C, K → H, H → E, V → D → BREACHED

Original Plaintext: SECURITYBREACHED

QUESTION 3.B

Q: Consider a Vigenère cipher where sixteen hexadecimal characters (0 to F) are used as the alphabet (instead of English letters).

i. For plaintext 3AE60A3 and keyword 17E, what will be the ciphertext?

ii. Using your answer in (i), argue that a polyalphabetic cipher such as the above is stronger against letter frequency analysis when compared to monoalphabetic ciphers like Caesar.

i. Ciphertext: 41C7784

Working:

Mapping hex to numbers 0–15: 3=3, A=10, E=14, 6=6, 0=0, A=10, 3=3.

Keyword 17E repeated: 1=1, 7=7, E=14, 1=1, 7=7, E=14, 1=1.

Addition modulo 16:

$$(3 + 1) \bmod 16 = 4$$

$$(10 + 7) \bmod 16 = 17 \bmod 16 = 1$$

$$(14 + 14) \bmod 16 = 28 \bmod 16 = 12 \text{ (C)}$$

$$(6 + 1) \bmod 16 = 7$$

$$(0 + 7) \bmod 16 = 7$$

$$(10 + 14) \bmod 16 = 24 \bmod 16 = 8$$

$$(3 + 1) \bmod 16 = 4$$

ii. Argument: In the plaintext, A appears twice (at positions 1 and 5). Due to the polyalphabetic shifts, the first A encrypts to 1, whereas the second A encrypts to 8. Because the same plaintext character is enciphered into different ciphertext symbols depending on the key position, the natural character frequency distribution is obscured and flattened.

Midterm 1 – Fall 2024

QUESTION 1.1

Q: What is the default access level to an object or resource according to fail-safe defaults?

- a. Read-only**
- b. Write-only**
- c. None**
- d. Full access**

Answer: c. None

QUESTION 1.4

Q: Passwords and/or sensitive data are read by (unauthorized) third parties ____

- a. Sniffing Attack**
- b. Spoofing Attack**
- c. Identity Theft Attack**
- d. Shadow Server**

Answer: a. Sniffing Attack

QUESTION 2.A

Q: Use the Rail Cipher to decrypt the following ciphertext, assuming a depth level of 3:

TPLEATA_NRM_ILRLCT_OKRSOUW_OE_UO

Answer: TRUMP WILL RELOCATE TO KASUR

QUESTION 2.B

Q: The following message is encrypted using the Vigenère cipher:

UQCG OQCG UQSV UQCG

What possible length could the keyword have and why?

Answer: Possible key length is 2 or 4.

Reasoning:

1- Find repeated strings in the ciphertext; their distance is expected to be a multiple of the key length.

2- Repeated digram UQ occurs at position 1 and 9 (distance = 8; factors: 2, 4), and at 9 and 13 (distance = 4; factor: 2).

Repeated digram CG occurs at position 3 and 7 (distance = 4; factor: 2), and at 7 and 15 (distance = 8; factors: 2, 4).

Computing $\gcd(8, 4, 4, 8) = 4$, the divisors are 2 and 4. Hence, key length is 2 or 4.

QUESTION 2.C

Q: Encrypt the following plaintext "samosa is ready" using the Row Transposition Cipher, with key "nick" (if your roll number ends with an even digit) or key "back" (if your roll number ends with an odd digit).

Working (using key "nick"):

(alphabetical column order: $c=1, i=2, k=3, n=4 \rightarrow 4\ 2\ 1\ 3$, or alphabetical ranking: $n=3, i=2, c=1, k=4$):

Writing row-by-row:

```
n i c k (Key Order: 3 2 1 4)
s a m o
s a i
s r e a
d y x x
```

Reading by column order 1, 2, 3, 4:

Col 1 (c): m, , e, x

Col 2 (i): a, a, r, y

Col 3 (n): s, s, s, d

Col 4 (k): o, i, a, x

Ciphertext: MEX AARY SSSD OIAX (or equivalent depending on numbering convention).

Midterm 1 – Fall 2023

QUESTION 1.1

Q: The process of identifying vulnerabilities and threats and their impact and probability of occurring an attack is called _____.

- a. Vulnerability assessment**
- b. Vulnerability identification**
- c. Threat detection**
- d. Risk analysis**

Answer: d. Risk analysis

QUESTION 1.2

Q: Receiving an SMS message where the sender's number is fake, is an attack against _____.

- a. Confidentiality**
- b. Integrity**
- c. Availability**
- d. Authenticity**

Answer: d. Authenticity

QUESTION 2 – PART I

Q: Identify the kind of attacks in each of the following statements and identify at least a couple of reasons the people fall for that:

a. You receive a phone call. The caller claims that they are from a bank, and ask your debit card number and OTP for the purpose of account confirmation, otherwise your account will be blocked.

b. You tried to login to your flex account during which you ignored a warning displayed by the browser and later on you came to know that your login credentials have been stolen.

c. The outgoing network traffic of your system has suddenly increased and on diagnosis, you have identified that your system is constantly sending a specific request to a server.

a. Social Engineering / Vishing (Voice Phishing). Reasons people fall for it: Psychological pressure (fear/urgency of account blocking) and perceived authority/familiarity.

b. Phishing / Man-in-the-Middle (SSL/TLS certificate spoofing). Reasons people fall for it: Carelessness and ignoring security warnings to save time or access convenience.

c. Bot / Zombie attack (system compromised as part of a botnet for DDoS).

QUESTION 2 – PART II

Q: We studied following security design principles: Least privilege, Failsafe defaults, Separation of privilege, Economy of mechanism, Psychological acceptability, Complete mediation, Least common mechanism. Analyze the following scenarios and identify, with reasoning, what security design principle is being applied? Also state what advantages are achieved due to that principle:

A. Marketing staff do not have access to engineering design files.

B. Company database is protected by only one layer of encryption rather than two layers.

A: Principle of Least Privilege. Staff are restricted strictly to the resources required for their assigned business role. Advantage: Limits unauthorized access and reduces risk/damage from internal compromised accounts.

B: Economy of Mechanism. Keeps the security mechanism simple, small, and streamlined instead of adding redundant, complex cryptographic layers. Advantage: Simpler design is easier to test, verify, maintain, and less prone to configuration/implementation flaws.

QUESTION 3.A

Q: Encrypt the text “voteforme” using Vigenère cipher with a key 245.

Ciphertext: XSYGJTQJ

Working:

Plaintext: v (21), o (14), t (19), e (4), f (5), o (14), r (17), m (12), e (4)

Key: 2, 4, 5, 2, 4, 5, 2, 4, 5

$(21 + 2) \bmod 26 = 23$ (x)

$(14 + 4) \bmod 26 = 18$ (s)

$(19 + 5) \bmod 26 = 24$ (y)

$(4 + 2) \bmod 26 = 6$ (g)

$(5 + 4) \bmod 26 = 9$ (j)

$(14 + 5) \bmod 26 = 19$ (t)

$(17 + 2) \bmod 26 = 19$ (t)

$(12 + 4) \bmod 26 = 16$ (q)

$(4 + 5) \bmod 26 = 9$ (j)

Midterm 1 – Fall 2022

QUESTION 1.5

Q: Which cyber security principle states that Security mechanisms should be as simple and small as possible?

- a) Complete mediation
- b) Least Privilege
- c) Economy of mechanism
- d) Open Design

Answer: c) Economy of mechanism

QUESTION 1.6

Q: Applying safeguards that eliminates or reduces residual risk is called defense strategy.

- a) Avoidance
- b) Acceptance
- c) Mitigation
- d) Transference

Answer: c) Mitigation

QUESTION 1.10

Q: Weakness of an asset is called threat. (True/False)

Answer: False (A weakness of an asset is a vulnerability; a threat is a potential harm).

QUESTION 2

Q: In each of the following scenarios, identify which security design principle is followed OR violated. Elaborate your response:

A. The company behind Telegram messenger hired some brilliant cryptographers to design proprietary security protocols for secret chats.

B. Staff at an airline booking office is required to provide their password as well as scan their smart card before confirming a booking.

C. A program successfully opens a file in write mode, but after a few hours, writing data to file fails due to permission errors.

A: **Violation of Open Design** because proprietary protocols cannot be subjected to open public scrutiny and evaluation by independent security experts.

B: **Separation of Privilege** is being followed, as multiple security conditions (two-factor credentials) must be satisfied before access is authorized.

C: **Complete Mediation** is being followed because the operating system does not rely on a one-time check at file opening, but verifies permissions continuously on every subsequent access attempt. (Alternate accepted: Least privilege via temporary privilege escalation).

Final Exams (Selected Questions)

FINAL EXAM – FALL 2022 • QUESTION 2.D

Q: Encrypt the following plaintext using a transposition cipher key 4132: SENSITIVE MESSAGE

Answer: ETMA SVSE NIEG SIES

Working:

Matrix with key header:

4	1	3	2
S	E	N	S
I	T	I	V
E	M	E	S
S	A	G	E

Read columns in key order (1, 2, 3, 4):

Col 1 (under 1): E T M A

Col 2 (under 2): S V S E

Col 3 (under 3): N I E G

Col 4 (under 4): S I E S

FINAL EXAM – FALL 2022 • QUESTION 3.A

Q: Principle of complete mediation cannot be applied 100%. Analyze the statement as correct or incorrect, and make your arguments.

Correct. If complete mediation were enforced 100% on every single hardware/software access, it would impose massive computational overhead, severely reducing system performance and degrading user experience.

Q: This problem explores the use of a one-time pad version of the Vigenère cipher. In this scheme, the key is a stream of random numbers between 0 and 26. For example, if the key is 3 19 5 ..., then the first letter of plaintext is encrypted with a shift of 3 letters, the second with a shift of 19 letters, the third with a shift of 5 letters, and so on.

a. Encrypt the plaintext “sendmoremoney” with the key stream:

9 0 1 7 23 15 21 14 11 11 2 8 9

b. Using the ciphertext produced in Part (a), find a key so that the ciphertext decrypts to the plaintext “cashnotneeded”.

a. Plaintext: s(18), e(4), n(13), d(3), m(12), o(14), r(17), e(4), m(12), o(14), n(13), e(4), y(24)

Key: 9, 0, 1, 7, 23, 15, 21, 14, 11, 11, 2, 8, 9

Add mod 26: $18+9=1$ (B), $4+0=4$ (E), $13+1=14$ (C), $3+7=10$ (K), $12+23=9$ (J), $14+15=3$ (D), $17+21=12$ (M), $4+14=18$ (S), $12+11=23$ (X), $14+11=25$ (Z), $13+2=15$ (P), $4+8=12$ (M), $24+9=7$ (H)

Ciphertext: BECKJ DMSXZ PMH

b. Desired Plaintext: c(2), a(0), s(18), h(7), n(13), o(14), t(19), n(13), e(4), e(4), d(3), e(4), d(3)

Required Key = (Ciphertext - Desired Plaintext) mod 26:

$$1 - 2 \equiv 25$$

$$4 - 0 \equiv 4$$

$$14 - 18 \equiv 22$$

$$10 - 7 \equiv 3$$

$$9 - 13 \equiv 22$$

$$3 - 14 \equiv 15$$

$$12 - 19 \equiv 19$$

$$18 - 13 \equiv 5$$

$$23 - 4 \equiv 19$$

$$25 - 4 \equiv 21$$

$$15 - 3 \equiv 12$$

$$12 - 4 \equiv 8$$

$$7 - 3 \equiv 4$$

Key: 25 4 22 3 22 15 19 5 19 21 12 8 4

Q: You studied four risk treatment (control) strategies. Identify which one has been followed in the given circumstances:

A company decides not to encrypt a low-value internal notice board.

A firm outsources hosting to a cloud provider with a service-level agreement.

A budgeting app refuses bank-account integration.

A company decides not to encrypt a low-value internal notice board: **Acceptance**

A firm outsources hosting to a cloud provider with a service-level agreement: **Transference**

A budgeting app refuses bank-account integration: **Avoidance**

Part 2: Book Questions

From: Computer Security: Principles and Practice (William Stallings) & Principles of Information Security (M. Whitman & H. Mattord)

WHITMAN & MATTORD / STALLINGS – CHAPTER 1 • QUESTION 1

Q: What specific information security property is violated in the following scenarios?

- A medical device displays incorrect dosage instructions because its software update was corrupted by a poor Internet connection.
- A weather forecasting system reports rain tomorrow, but the data fed into it had mistakes, leading to a wrong prediction.
- A fitness app sells users' location and health data to advertisers without their consent.
- An online shopping site shows the wrong price for an item because an attacker tampered with its database.

Integrity

Accuracy

Privacy (Confidentiality)

Integrity

WHITMAN & MATTORD / STALLINGS – CHAPTER 1 • QUESTION 2

Q: What specific information security property is violated in the following scenarios?

- An employee receives an email that looks like it is from their CEO, but it was actually sent by an attacker pretending to be them.
- A company cannot find out who made unauthorized changes to critical financial records because logging was disabled.
- During an online exam, a student uses someone else's credentials to log in and take the test.
- A company's internal emails are intercepted and read by a competitor while being transmitted.

Authenticity

Accountability

Authenticity

Confidentiality

Q: Analyze the following scenario and identify the vulnerability, the threat, and the attack:

Scenario: A house has a broken lock on the front door that the owner never got around to fixing. In the same neighborhood, a burglar is on the lookout for easy targets. One night, the burglar notices the weak lock, manages to get inside, and steals valuable items from the house.

Vulnerability: The broken lock on the front door (an existing flaw/weakness in an asset).

Threat: The burglar in the neighborhood looking for easy targets (a potential danger to the asset).

Attack: The burglar noticing the lock, entering, and stealing items (active exploitation of the vulnerability; the threat realized).

Q: According to Stallings' classification of attacks and security consequences, how do Passive and Active attacks differ, and how do Inside and Outside attacks differ?

Active vs. Passive: In passive attacks, the adversary does not interact directly with or alter system entities (e.g., eavesdropping, wiretapping, packet sniffing). In active attacks, the adversary alters system resources or affects system operations.

Inside vs. Outside: Inside attacks originate from authorized entities within an organization with legitimate security perimeters; outside attacks originate from external entities not authorized to access internal systems.

Q: Based on Stallings' security taxonomy, match the following consequences with their threat actions:

Unauthorized Disclosure: Exposure, Interception, Inference, Intrusion

Deception: Masquerade, Falsification, Repudiation

Disruption: Incapacitation, Corruption, Obstruction

Usurpation: Misappropriation, Misuse

Unauthorized Disclosure: Exposure (direct release of sensitive data), Interception (direct unauthorized access to data in transit), Inference (indirect reasoning from traffic by-products), Intrusion (circumventing perimeter controls).

Deception: Masquerade (impersonating an authorized entity), Falsification (delivering altered/false data), Repudiation (falsely denying responsibility).

Disruption: Incapacitation (disabling components), Corruption (undesirable alteration of system data), Obstruction (hindering system service delivery).

Usurpation: Misappropriation (taking physical or logical control of resources), Misuse (causing component to run detrimentally).

Q: What is the size of the key space in a monoalphabetic substitution cipher assuming an alphabet of 26 letters?

- a. 26
- b. 26!
- c. 2^{26}
- d. 26^2

Answer: b. 26! ($\approx 4 \times 10^{26}$, making brute-force search infeasible, though easily broken by letter frequency analysis).

Q: Are permutation (transposition) ciphers susceptible to letter frequency analysis? Explain why or why not.

No. In a permutation cipher, characters are rearranged rather than substituted. As a result, the ciphertext contains the exact same letter frequencies as the plaintext. While frequency analysis immediately reveals to an analyst that a transposition cipher was used, it does not assist in determining the transposition key or order.

Q: What are the key limitations of the One-Time Pad (OTP) cipher that render it impractical for general real-world applications despite providing perfect secrecy?

- The key must be completely random and at least as long as the plaintext message.
- Transmitting a key of equal size to the message over a secure channel requires enormous bandwidth and storage (e.g., transmitting a 100 MB key to send a 100 MB file), recreating the original key exchange dilemma.
- Keys can never be reused under any circumstances.

Q: How does Kasiski's method work to deduce the unknown key length m of a polyalphabetic Vigenère cipher?

1. Locate repeated multi-character sequences (digrams, trigrams) in the ciphertext.
2. Measure the distances (character intervals) between the repeated occurrences.
3. Factor the distances and compute the greatest common divisor (*gcd*) of these intervals. The true key length is almost certainly this *gcd* or one of its common multiples.

Q: How does homophonic substitution harden a monoalphabetic cipher against single-letter frequency attacks?

It provides multiple cipher symbols (homophones) for a single high-frequency letter (e.g., assigning four symbols like 16, 74, 35, 21 to the letter 'e') in proportion to that letter's natural frequency, thereby obliterating the characteristic frequency spikes of individual letters.